



Security Culture 2.0

Enrique Larios-Vargas
Nick Miller

Frontispiece

Copyright and Licensee

Copyright (c) 2026 The OWASP Foundation.

This work is licensed under a [Creative Commons Attribution-ShareAlike 4.0 International License](#). Please read and understand the license and copyright conditions.

Leaders

- Enrique Larios-Vargas
- Nick Miller

Collaborators

- Michael L. W. Vliek
- Nicolas Humblot
- David Freeman

SECUR-E Developer Security Self-Assessment Tool

Deliverable 1 - Psychometric Scales (COM-B aligned)

We introduce the **SECUR-E Developer Personas Framework**, a self-assessment tool to measure developers' engagement with secure practices. This framework is based exclusively on the [DASP framework](#) (Larios-Vargas et al., 2023)¹ and the [COM-B Model](#) (Michie et al., 2011)². Each item in the framework is linked to empirical findings and behavioral constructs from these two sources.

1. Purpose and Scope of the Scales

These psychometric scales operationalize the three COM-B dimensions, Capability, Opportunity, and Motivation, as expressed in the COM-B model and grounded in the 33 behavioral drivers identified by the DASP study. They are designed to be administered as part of the SECUR-E self-assessment system but can function as standalone diagnostic instruments. The primary output is a scored behavioral profile that supports classification into one of six SECUR-E personas: *Skeptic*, *Enthusiast*, *Compliant*, *Unaware*, *Resistant*, or *Embedded*.

The scales are intentionally practitioner-facing: items are written in plain language, avoiding jargon, to ensure developers and security teams feel confident in the system's clarity and ease of interpretation, reinforcing its practical applicability.

2. Scoring Key and Scale Anchors

The table below displays the five response anchors utilized across all three subscales. Please note that items marked with [R] are reverse-scored: when calculating subscale totals, subtract the raw response from 6. For example, a raw score of 1 (Strongly Disagree) will become a scored value of 5, and a raw score of 5 (Strongly Agree) will become a scored value of 1. This adjustment ensures that higher subscale scores consistently reflect greater levels of the construct being measured.

1	2	3	4	5
Strongly Disagree	Disagree	Neither Agree nor Disagree	Agree	Strongly Agree

Reverse-scoring formula: Scored value = 6 minus the raw response. Apply this to all items marked [R] before summing the subscale. Subscale range: 8 (minimum) to 40 (maximum).

3. Capability Subscale (CAP)

The COM-B model serves as a diagnostic tool for understanding barriers to capability, specifically the obstacles that prevent the adoption of security practices. It explores why developers may lack knowledge or have difficulty applying these security practices.

3.1 Construct Definition

Capability in the COM-B model includes psychological capability, knowledge, awareness, self-efficacy, the cognitive bandwidth to attend to security amid competing priorities, and physical capability, which in the software security context is translated by DASP into

¹ Larios-Vargas, E., Elazhary, O., Yousefi, S., Lowlind, D., Vliek, M. L. W., & Storey, M.-A. (2023). DASP: A Framework for Driving the Adoption of Software Security Practices. *IEEE Transactions on Software Engineering*, 49(4), 2892-2919.

² Michie, S., van Stralen, M. M., & West, R. (2011). The behaviour change wheel: A new method for characterising and designing behaviour change interventions. *Implementation Science*, 6(1), 42.

technical skills (the ability to perform security practices, understand exploits, and apply patches) and non-technical skills (communication, critical thinking, and stakeholder collaboration). Table 3 of the DASP paper provides the definitive adaptation of COM-B's capability construct to software security.

In the SECUR-E persona framework, "*capability*" is the primary diagnostic measure for the Unaware persona, which is characterized by very low knowledge and skills. It also serves as the secondary distinguishing factor between the Skeptic persona, which has moderate capability and low motivation, and the Embedded persona, which displays high capability and high motivation. Additionally, a developer can possess high capability yet still act insecurely if they lack opportunity or motivation; this is described as the Compliant profile. Therefore, capability scores should always be interpreted alongside the other subscales.

3.2 Item Set (CAP-1 through CAP-8)

Items CAP-4, CAP-6, and CAP-8 are reverse-scored, as indicated by [R] in the Direction column. Higher total CAP scores indicate greater security capability.

Code	Survey Item	Dir.	Research Basis (DASP)
CAP-1	I can recognize common security vulnerabilities, such as injection flaws or insecure authentication, in code I write or review.	+	<i>SECUR-E: Skeptic persona is defined by the ability to 'identify common vulnerabilities such as SQL injection and XSS.' Measures the foundational security knowledge threshold. DASP D33: Awareness of necessary security skills.</i>
CAP-2	When a security tool or code review flags a problem in my work, I know how to assess it and take appropriate action.	+	<i>DASP D32: Confidence in technical abilities. SECUR-E: Compliant is described as 'proficient with security tools' and responsive to tool alerts. Distinguishes Compliant/Embedded from Unaware.</i>
CAP-3	I understand how the technical decisions I make during development can affect the security of the software I build.	+	<i>SECUR-E: Embedded persona: 'When designing features, they automatically consider security implications.' DASP D12 Psychological capability: awareness of how decisions create risk. Core discriminator for Unaware vs. all other personas.</i>
CAP-4	Security concepts and best practices feel largely out of reach for my current skill level.	[R]	<i>SECUR-E Unaware: 'low security capabilities... lack fundamental security knowledge.' DASP D32 reversed. Captures the low-capability anchor. Dunning-Kruger³ effect noted for Unaware in the SECUR-E personas.</i>
CAP-5	I can explain a security risk clearly enough for a non-technical colleague or manager to understand why it matters.	+	<i>DASP D31: Non-Technical capabilities, 'communication is one of the most important non-technical skills.' All 28 DASP practitioners identified communication as critical. Maps to psychological + non-technical capability.</i>
CAP-6	I often discover security problems in my work only after someone else has pointed them out to me.	[R]	<i>SECUR-E Unaware: 'Insecure code is not due to negligence but to genuine lack of awareness.' Metacognitive gap explicitly referenced via Kruger & Dunning [1999]. DASP D32 was reversed for the metacognitive dimension.</i>
CAP-7	I have a clear sense of which security skills I still need to develop.	+	<i>DASP D33: Awareness of necessary security skills. Captures constructive metacognitive awareness, knowing one's own gaps, which is distinct from</i>

³ Justin Kruger and David Dunning. 1999. Unskilled and unaware of it: How difficulties in recognizing one's own incompetence lead to inflated self-assessments. 77, 6 (1999), 1121–1134. doi:10.1037/0022-3514.77.6.112was 1

Code	Survey Item	Dir.	Research Basis (DASP)
			<i>overconfidence (also flagged in D32 as a risk). Maps to Psychological capability.</i>
CAP-8	Security tools in my workflow are too complex for me to use effectively without significant guidance.	[R]	<i>DASP D23: Improving usability and accuracy of security tools. DASP D9 tool awareness. Captures the intersection of capability and tool usability.</i>

Subscale Summary: Capability (CAP)

8 items | Reverse-scored: CAP-4, CAP-6, CAP-8 | Range: 8-40 | Higher scores = Greater capability. Items span: foundational security knowledge (CAP-1, CAP-3), self-efficacy and confidence (CAP-2, CAP-4), metacognitive awareness (CAP-6, CAP-7), non-technical communication capability (CAP-5), and tool usability as a capability constraint (CAP-8).

4. Opportunity Subscale (OPP)

The COM-B model is a diagnostic tool designed to identify barriers to Opportunity, particularly obstacles in a developer's environment that may hinder effective adoption of security practices.

4.1 Construct Definition

Opportunity includes social opportunity, interpersonal influences, team norms, organizational culture, peer behavior that creates (or closes) the space for security action, and technical (physical) opportunity, which in DASP is understood as access to tools, time allocation, organizational policies, and resources. DASP influences SECUR-E by recognizing that organizational culture and social opportunity are stronger predictors of security behavior than individual motivation or capability for most developer personas. The DASP finding that 23 of 28 practitioners cited *social perception of security adoption* as a significant driver is one of the strongest empirical signals in this study.

The Enthusiast persona is the critical test case for the opportunity construct: Enthusiasts have high motivation and moderate-to-high capability but often work in low-opportunity environments. Their behavior demonstrates that strong motivation can partially compensate for limited opportunity, but Enthusiasts risk burnout precisely because they must work against their organizational context. The Compliant persona, by contrast, is essentially an opportunity-driven behavioral pattern: security occurs when the environment mandates and supports it, and ceases when it does not.

4.2 Item Set (OPP-1 through OPP-8)

Items OPP-4, OPP-6, and OPP-8 are reverse-scored, as indicated by [R]. Higher total OPP scores indicate richer security opportunity environments.

Code	Survey Item	Dir.	Research Basis (DASP / SECUR-E)
OPP-1	My team treats security discussions as a normal, expected part of how we develop software.	+	<i>DASP D6: Social perception of security adoption, cited by 23 of 28 practitioners, the single most widely endorsed driver.</i>

Code	Survey Item	Dir.	Research Basis (DASP / SECUR-E)
OPP-2	I have access to security tools that fit naturally into my existing development workflow.	+	DASP D9: Tool awareness (technical opportunity). D25: Integrating tools into the development workflow. Distinguishes high vs. low technical opportunity profiles.
OPP-3	There is at least one person in my organization, a security expert, champion, or knowledgeable colleague, whom I can turn to for security support.	+	DASP D3: Having a security-specific role filled, cited by 14 practitioners.
OPP-4	Delivery pressure in my organization regularly pushes security work to the back of the queue.	[R]	DASP D1 + D2: The most widely cited barrier among DASP drivers.
OPP-5	My organization allocates dedicated time or resources for security-related work.	+	DASP D2: Prioritizing security practices, cited by 17 practitioners. Technical opportunity via resource allocation. Distinguishes Compliant (high) from Enthusiast (often low).
OPP-6	Security tools I use generate so many false alerts that I have largely stopped relying on them.	[R]	DASP D23: Improving usability and accuracy of security tools. Key trigger for Skeptic persona and driver of Resistant behavior per SECUR-E.
OPP-7	When someone on my team raises a security concern, it is genuinely taken seriously.	+	DASP D1: Organizational culture, reflective motivation dimension. D6: Social perception. Differentiates a genuinely security-positive culture from one that mandates but does not support security.
OPP-8	In my workplace, security is generally treated as the responsibility of a specialist team, not individual developers.	[R]	DASP D3 counterpart: Practitioners note security 'abstracted away from development', but SECUR-E warns this produces Compliant or Unaware profiles. DASP D6: When responsibility is externalized, individual motivation and capability fail to develop. Social opportunity reversed.

Subscale Summary: Opportunity (OPP)

8 items | Reverse-scored: OPP-4, OPP-6, OPP-8 | Range: 8-40 | Higher scores = Richer opportunity environment. Items span: team security norms (OPP-1, OPP-7), tool access and quality (OPP-2, OPP-6), expertise access and security champions (OPP-3), organizational time and resource allocation (OPP-5), delivery pressure as opportunity barrier (OPP-4), and security responsibility distribution (OPP-8).

5. Motivation Subscale (MOT)

The COM-B model serves as a diagnostic tool for understanding barriers to Motivation, specifically the obstacles that prevent the adoption of security practices. It explores why developers may lack the drive or face internal resistance toward applying security practices.

5.1 Construct Definition

Motivation in the COM-B model is divided into two main categories: reflective motivation and automatic motivation. Reflective motivation involves conscious beliefs, evaluations, and attitudes regarding the value, necessity, and importance of security. On the other hand, automatic

motivation covers habits, emotional reactions, identity-based responses, and instinctive tendencies. In developer security behavior, the most important automatic motivation construct is security as professional identity: whether security is experienced as part of what it means to be a good developer, or as an imposition from outside.

The motivation subscale is the most powerful discriminator across the SECUR-E persona space. The Embedded persona is defined by high intrinsic, habitual motivation. The Enthusiast shares high intrinsic motivation but with a more effortful, conscious quality. The Compliant persona has adequate reflective motivation only under external enforcement and extrinsic motivation, per Tyler & Blader (2005)⁴. The Skeptic doubts the reflective case for security ROI. The Resistant persona displays negative automatic motivation rooted in psychological reactance (Brehm, 1966)⁵: security requirements are perceived as threats to autonomy, triggering opposition. The Unaware has very little motivation for either type, primarily because the problem space is not yet visible to them.

5.2 Item Set (MOT-1 through MOT-8)

Items MOT-3, MOT-5, and MOT-7 are reverse-scored, as indicated by [R]. Higher total MOT scores indicate stronger and more intrinsic security motivation.

Code	Survey Item	Dir.	Research Basis (DASP / SECUR-E)
MOT-1	I believe that writing secure code is just as important as writing code that works correctly.	+	<i>SECUR-E Embedded persona, defining characteristic. DASP D15: Knowledge of the benefits of security adoption. The core reflective motivation item tests security's position in a developer's value hierarchy.</i>
MOT-2	Thinking about security feels like a natural, instinctive part of how I approach development, not a separate task I add afterward.	+	<i>SECUR-E Embedded: 'security is habitual rather than requiring conscious effort, repeated behaviors embedded in daily routines become automatic and self-sustaining. DASP D8 automatic motivation. Captures habituation, the hallmark of the Embedded persona.</i>
MOT-3	The security requirements I am expected to follow often feel like unnecessary overhead that slows me down.	[R]	<i>SECUR-E Resistant, defining characteristic. DASP D21: Developers' perception of security-imposed restrictions. Psychological reactance theory (Brehm, 1966). Automatic motivation reversed.</i>
MOT-4	I actively look for ways to improve security in my work, even when no one is requiring me to.	+	<i>SECUR-E Enthusiast: 'champion security even under time pressure... integrate security into their work despite obstacles rather than because of ideal conditions.' DASP D8: Shaping developer attitudes; proactive behavior (Crant, 2000)⁶. Key discriminator: Enthusiast and Embedded vs. all others.</i>
MOT-5	I follow security practices mainly because they are required, not because I personally believe in their value.	[R]	<i>SECUR-E Compliant, defining characteristic. Tyler & Blader's (2005) external motivation model distinguishes extrinsic (Compliant) from intrinsic (Enthusiast/Embedded) motivation.</i>
MOT-6	I feel a personal responsibility to protect the people who use the software I build.	+	<i>DASP D16: Promoting a customer satisfaction/protection mindset. Automatic motivation via identity and user responsibility is strongly associated with the Embedded persona.</i>

⁴ Tom R. Tyler and Steven L. Blader. 2005. Can Businesses Effectively Regulate Employee Conduct? The Antecedents of Rule Following in Work Settings. 48, 6 (2005), 1143–1158. doi:10.5465/amj.2005.19573114

⁵ J.W. Brehm. 1966. A Theory of Psychological Reactance. Academic Press. <https://books.google.com.pe/books?id=0uN9AAAAAAAJ>

⁶ J. Michael Crant. 2000. Proactive behavior in organizations. 26, 3 (2000), 435–462. doi:10.1016/S0149-2063(00)00044-1

Code	Survey Item	Dir.	Research Basis (DASP / SECUR-E)
MOT-7	The amount of security effort my work requires seems disproportionate to the actual risk of being attacked.	[R]	<i>SECUR-E Skeptic, defining characteristic. 'They note that their applications have never been attacked, leading them to question the necessity of security investments.' Prospect theory and bounded rationality (Kahneman & Tversky, 1979)⁷. DASP D12 reversed via risk underestimation.</i>
MOT-8	I keep my security knowledge up to date through self-directed learning, beyond what my organization formally provides.	+	<i>SECUR-E Enthusiast: 'actively self-educate through online courses, security conferences, capture-the-flag competitions, and security-focused side projects.' DASP D26: Accessibility to learning resources; D29: Self-learning. Automatic motivation via identity as a security-minded developer.</i>

Subscale Summary: Motivation (MOT)

8 items | Reverse-scored: MOT-3, MOT-5, MOT-7 | Range: 8-40 | Higher scores = Stronger intrinsic motivation. Items span: security as professional value (MOT-1), habitual/automatic security thinking (MOT-2), resistance and reactance (MOT-3), proactive security behavior (MOT-4), extrinsic-only motivation (MOT-5), user-protective identity (MOT-6), risk skepticism (MOT-7), and self-directed learning drive (MOT-8).

6. Subscale Overview and Item Coverage

The table below provides a consolidated reference showing the three subscales, item counts, reverse-scored items, COM-B facets covered, and primary DASP drivers addressed. All 24 items across the three subscales can be administered together in approximately 6-8 minutes.

Subscale	Items (n)	Reverse-Scored	Primary COM-B Components Covered	Key DASP Drivers
Capability (CAP)	8	CAP-4, CAP-6, CAP-8	Technical skills, Psychological capability (self-efficacy, metacognition), Non-technical skills	D31, D32, D33, D12, D23
Opportunity (OPP)	8	OPP-4, OPP-6, OPP-8	Social opportunity (team norms, culture, champions), Technical opportunity (tools, time, resources)	D1, D2, D3, D6, D9, D23, D25
Motivation (MOT)	8	MOT-3, MOT-5, MOT-7	Reflective motivation (beliefs, ROI, value), Automatic motivation (habits, identity, responsibility)	D8, D14, D15, D16, D21, D26

Note: DASP driver codes (D1-D33) correspond to the 33 behavioral drivers identified in Larios-Vargas et al. (2023), Table 5. Each item's full research basis is documented in the item tables above.

⁷ Daniel Kahneman and Amos Tversky. 1979. Prospect Theory: An Analysis of Decision under Risk. 47, 2 (1979), 263. doi:10.2307/1914185

7. Interpretation Notes for Practitioners

Three practical interpretive principles should be kept in mind when working with raw subscale scores.

- First, interpret subscale profiles rather than individual items. A single low-scoring item may reflect a domain-specific context (such as D18, application characteristics affecting security relevance) rather than a genuine capability or motivation deficit. The subscale total is the unit of interpretation.
- Second, the opportunity subscale has the strongest empirical basis in DASP for organizational-level interpretation. DASP's finding that culture and social opportunity are the strongest predictors of security behavior means that low OPP scores at the team level are a higher-priority intervention target than individual CAP or MOT deficits. If most members of a team score low on OPP, the diagnosis is organizational rather than individual.
- Third, reverse-scored items serve dual purposes: they reduce acquiescence bias and are the most direct diagnostic signals. A developer who strongly agrees with MOT-3 ('security requirements feel like unnecessary overhead') and MOT-7 ('disproportionate to actual risk') while scoring low on MOT-4 and MOT-1 is providing a coherent signal toward a Skeptic or Resistant profile that the total score alone may partially obscure. Where time permits, practitioners should review item-level responses alongside subscale totals.

8. Main References

All items and constructs in this document are traceable to the following primary sources:

- Larios-Vargas, E., Elazhary, O., Yousefi, S., Lowlind, D., Vliek, M. L. W., & Storey, M.-A. (2023). DASP: A Framework for Driving the Adoption of Software Security Practices. *IEEE Transactions on Software Engineering*, 49(4), 2892-2919.
- Michie, S., van Stralen, M. M., & West, R. (2011). The behavior change wheel: A new method for characterizing and designing behavior change interventions. *Implementation Science*, 6(1), 42.